

## The SOC and Its Role

*A Security Operations Center is a centralized unit within an organization that deals with security issues, incidents, and events.*

- **Monitor**
  - Continuous observation for unusual activity
  - Utilization of monitoring tools (IDS, SIEM, etc.) for real-time visibility
  - Early detections of potential security threats
- **Detect**
  - Confirm security events identified during monitoring
  - Utilize threat detection techniques
  - Identify known indicators of compromise (IOCs)
- **Analyze**
  - Perform in-depth investigations to understand security incidents
  - Examine affected systems, build a timeline of events
  - Trace tactics, techniques, and procedures (TTPs)
- **Respond**
  - Formulate a response plan based on findings
  - Contain threats, mitigate impact, and restore normal operations

## Key Functions of a SOC

### Reactive

- **Monitoring and Detection**
  - Network and system logs, alerts
  - SIEM, IDS, log analysis
  - Alert triage
- **Incident Response**
  - Investigate, contain, and mitigate threats
  - Collect evidence and artifacts
  - Engage with stakeholders
- **Forensic Analysis**
  - In-house or third-party
  - Determine cause and scope
  - Preserve evidence and engage legal
- **Malware Analysis**
  - In-house or third-party
  - Sandbox and reverse engineer malware
  - Study malware behavior
  - Collect indicators of compromise

### Proactive

- **Threat Intelligence**
  - Gather and analyze intelligence
  - Study emerging threats, vulnerabilities, and attacks
  - Feed intel into detection tools for proactive defense
- **Threat Hunting**
  - Search for malicious activity or intrusions
  - Logs, network traffic, endpoint telemetry
  - Utilize threat intelligence to hunt for known indicators
- **Vulnerability Management**
  - Identify and address vulnerabilities
  - Scan, assess, and patch
  - Coordinate remediation activity
- **Security Awareness Training**
  - Promote security awareness within the organization
  - Educate best practices, policies, and procedures
  - Mitigate human error leading to incidents

# Day in the Life of a SOC Analyst

- **Rotating schedules (sometimes)**
- **Alert Triage**
  - Monitoring the alert ticket queue
  - Assess credibility and severity
- **Incident Triage**
  - Information gathering
  - Follow processes
- **First-Line Analysis and Investigation**
  - Use tools and techniques to assess the incident
  - Logs, network traffic, configurations, OSINT
- **Documentation and Reporting**
  - Clear and concise
  - Findings, actions, resolutions
- **Escalation and Collaboration**
  - Coordinate response activities
- **Continuous Improvement and Cross-Training**



## Information Security Refresher

### CIA Triad

- **Confidentiality**
  - Protection of sensitive information from unauthorized access
  - Ensures data is only accessible to those with proper authorization
- **Integrity**
  - Ensures that data remains accurate, reliable, and consistent
- **Availability**
  - Ensures that data and resources are accessible and usable when needed



### AAA Framework

- **Authentication**
  - Verifies the identity of users attempting to access a system or resource
  - Password, key, or other authentication methods
- **Authorization**
  - What actions or operations are we allowed to perform?
  - Access levels based on roles, permissions, or privileges
- **Accounting**
  - Tracking and recording activities within a system



## Information Security Refresher

- **Vulnerability**
  - Weaknesses in systems, networks, or processes
  - Can be exploited by threats to compromise CIA
  - Exposes the organization to **threats**
- **Threat**
  - Any potential danger to information or systems
  - Malware, phishing, denial of service
  - Takes advantage of a **vulnerability**
- **Risk**
  - Likelihood of a **threat** exploiting a **vulnerability**
  - Potential for loss and damage when a **threat** occurs



# Information Security Refresher

- **Log**
  - A record of events or actions that have occurred within a system
  - Used for monitoring and troubleshooting security incidents
- **Security Event**
  - Any observable occurrence that has a potential significance for security
  - All incidents are events, but not all events are incidents
- **Security Incident**
  - An occurrence that actually harms or jeopardizes information or systems
  - Constitutes a violation of law, security policies, procedures, or acceptable use
- **Alert**
  - A notification generated by security systems or personnel
  - Indication of a potential security issue or suspicious activity



## Security Controls

- **Defense in Depth**
  - Strategy of layered security
  - Multiple barriers to threats
- **Administrative Controls**
  - Security policies
  - Change management procedures
  - Incident response plans
- **Technical Controls**
  - Firewalls, EDR
  - Intrusion Detection Systems
  - Two-Factor Authentication
- **Physical Controls**
  - Access control systems



# Security Control Functions

- **Preventative Control**
  - Eliminate or reduce likelihood of an attack succeeding
  - ACLs, firewalls, EDR, IPS
- **Detective Control**
  - Identify and record attempted or successful intrusions
  - IDS, SIEM, logs, surveillance cameras
- **Corrective Control**
  - Eliminate or reduce the impact of an intrusion
  - Backups, IR plans, patch management
- **Deterrent Control**
  - Discourages intrusion attempts
  - Physical barriers, signage, tamper seals





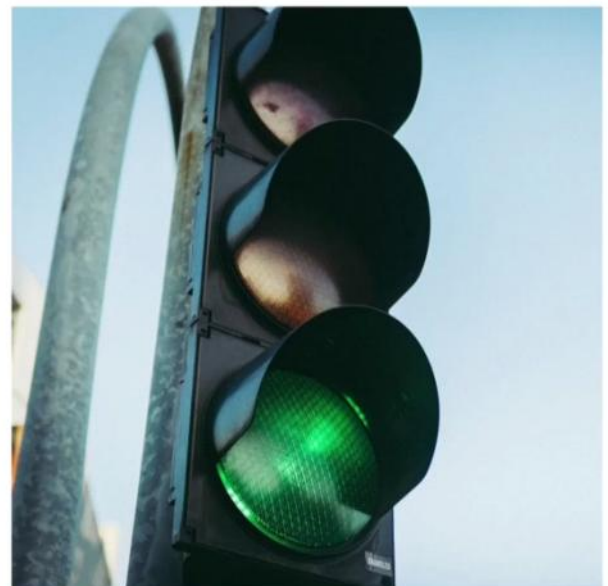
## Incident Management

- **Incident Identification**
  - Event management escalation
  - Detection mechanisms
- **Incident Classification**
  - Severity, impact, and nature
- **Incident Investigation**
  - Gather evidence, determine scope
- **Incident Containment**
  - Prevent further escalation
- **Incident Eradication**
  - Remove evil
- **Incident Recovery**



## Detection Outcomes

- **False Positive**
  - Incorrect identification of benign activity
- **True Positive**
  - Correct identification of a real security incident
- **False Negative**
  - Failed detection of a real security threat 🤖
- **True Negative**
  - Correct identification of benign activity



## SOC Metrics

*"If you can't measure it, you can't improve it." – Peter Drucker*

- **Mean Time to Detect (MTTD)**
  - Lower MTTD = faster detection
- **Mean Time to Resolution (MTTR)**
  - Lower MTTR = more efficient IR
- **Mean Time to Attend and Analyze (MTTA&A)**
  - Lower MTTA&A = reduced response latency
- **Incident Detection Rate**
  - Higher rate = better visibility and monitoring
- **False Positive Rates (FPR)**
  - Lower rate = more accurate detection
- **False Negative Rates (FNR)**
  - Lower rate = more accurate detection
- **Key Performance Indicators (KPIs)**
  - Measurable values to track performance
- **Key Risk Indicators (KRIs)**
  - Measurable values to assess risk
- **Service Level Agreements (SLAs)**

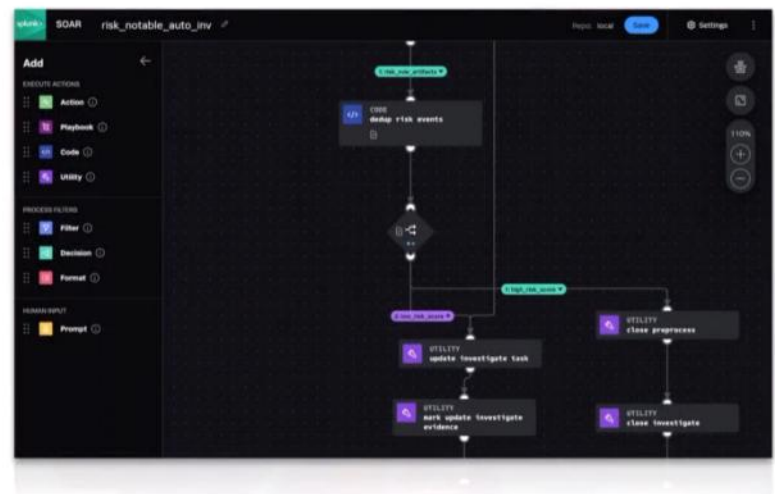
## Security Information and Event Management (SIEM)

- Log Management
- Real-time Monitoring
- Alerting and Notification
- Incident Response
- Dashboards, Reports, and Visualization
- Threat Intelligence Integration



## Security Orchestration, Automation, and Response (SOAR)

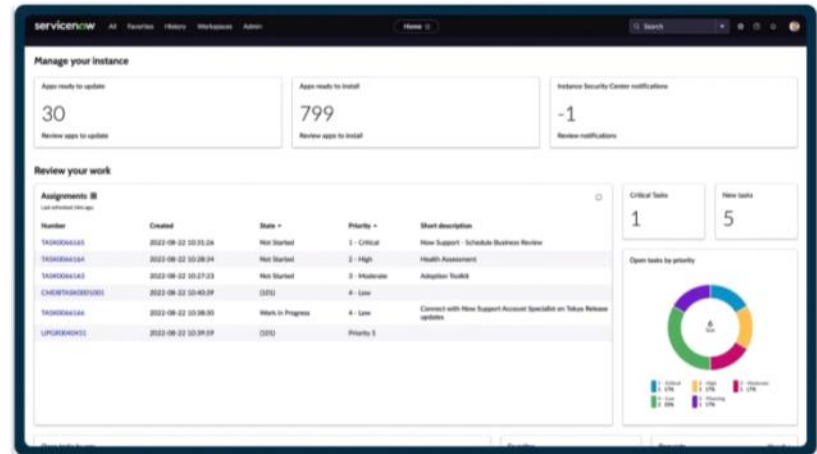
- Orchestration
  - Workflows
  - Collaboration
- Automation
  - Alert triage
  - Artifact collection
  - Data enrichment
- Incident Response
  - Assess and prioritize
- Integration
  - TIPS, EDR, firewalls, etc.
- Analytics and Intelligence





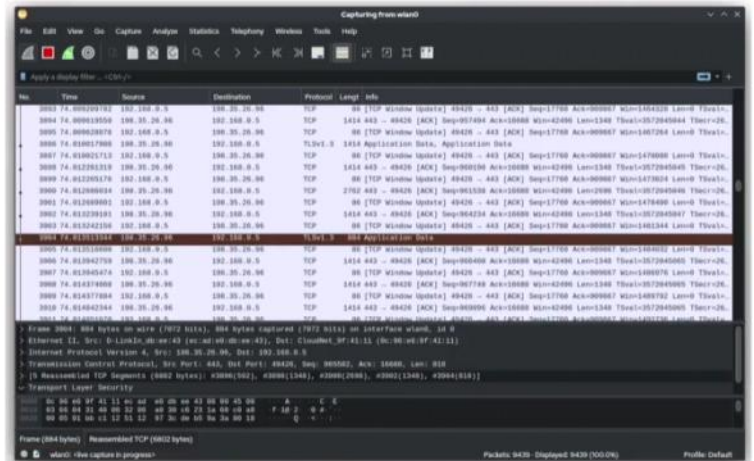
# Incident Management Tools

- Incident Ticketing
  - Documentation
  - Tracking
  - Assigning
- Alert Management
- Workflow Automation
- Collaboration



# Network Security Monitoring (NSM)

- Packet Capture and Analysis
  - Real time, or with captures
- Network Traffic Analysis
  - Statistical analysis
  - Machine learning
  - Behavior analysis
- Intrusion Detection
  - IDS functionality
- Integration with SIEM
  - Correlate network events with endpoint telemetry



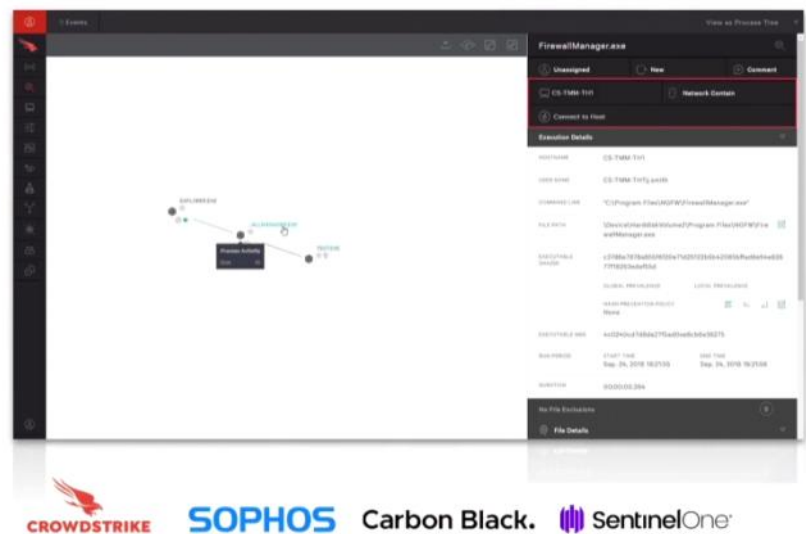
# Intrusion Detection and Prevention Systems (IDS/IPS)

- Passive or active monitoring
- Generate alerts
- Actively block and prevent threats
- Logging and reporting



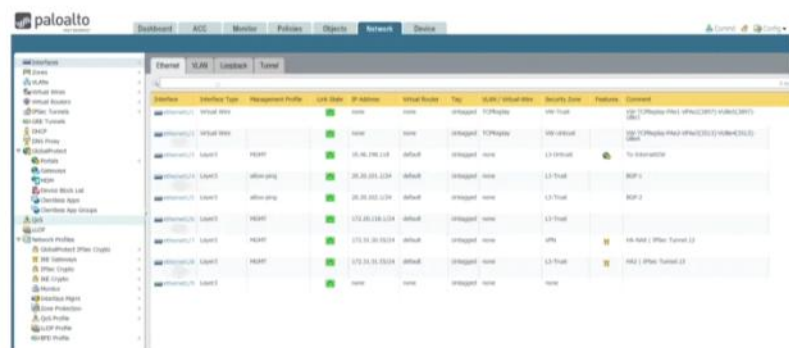
# Endpoint Detection and Response (EDR)

- Real-time Endpoint Monitoring
- User Entity Behavior Analytics (UEBA)
- Threat Detection and Prevention
- Incident Investigation
- Remediation and Response
- Integration with SIEM



# Firewalls

- **Network Firewalls**
  - Examine packets
  - Layer 3
  - Make decisions based on rules
- **Next-Generation Firewalls (NGFW)**
  - Stateful packet inspection
  - Deep packet inspection
  - Layer 7
- **Web Application Firewalls**
  - Inspect HTTP(S) traffic
  - Protect web applications from attacks
  - Layer 7



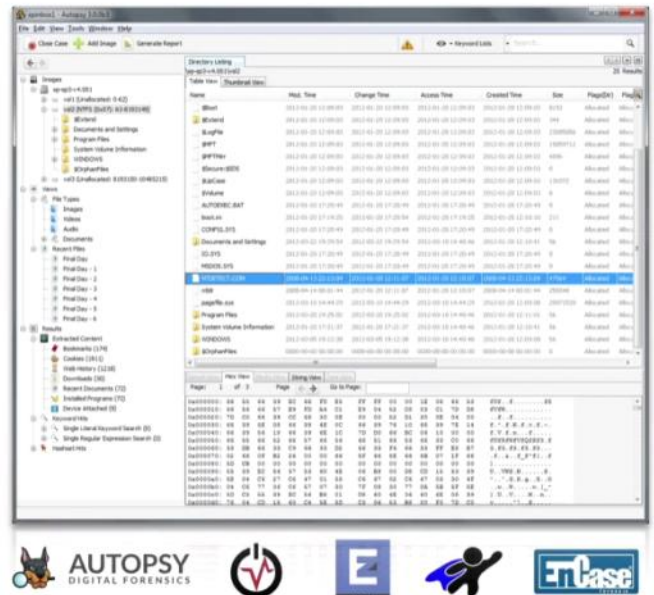
# Threat Intelligence Platforms (TIP)

- Data Aggregation and Enrichment
- Indicators of Compromise (IOCs)
- Normalization and Standardization
- Analysis and Prioritization
- Integration with SIEM



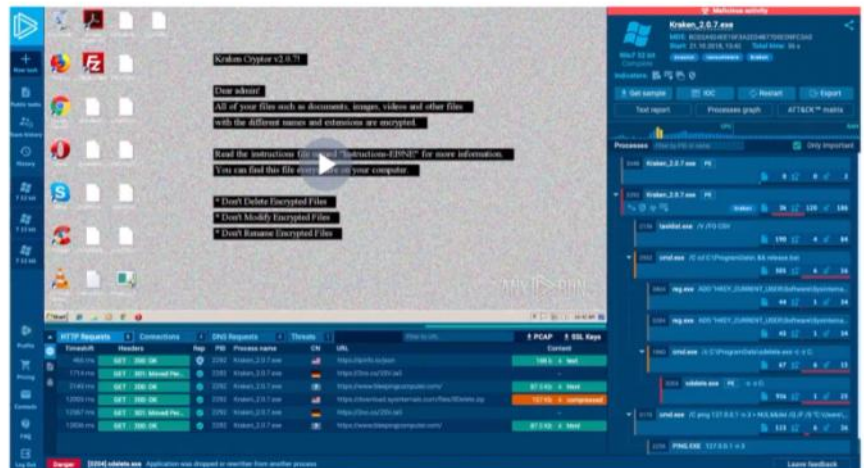
# Forensic Analysis Tools

- Data Acquisition and Imaging
- File System Analysis
- Memory Forensics
- Registry Forensics
- Network Traffic Forensics



# Malware Analysis Tools

- Dynamic Analysis
- Static Analysis
- Behavioral Analysis
- Signature and Pattern Matching





# Common Threats and Attacks

- **Social Engineering**
  - Phishing
  - Spoofing
  - Vishing
  - SMiShing
  - Quishing
- **Malware**
  - Worm, Spyware, Adware
  - Ransomware
  - Trojan
  - Fileless Malware
- **Identity and Account Compromise**
  - Credential Theft
- **Insider Threats**
- **Advanced Persistent Threats (APTs)**
- **Denial-of-Service Attacks**
- **Data Breaches**
- **Zero-Days**
- **Supply Chain Attacks**

